

Grupo de trabajo de red D. Brezinski
Solicitud de comentarios: 3227 In-Q-Tel
BCP: 55 T. Killalea
Categoría: Mejor práctica actual neart.org

Febrero de 2002

Pautas para la recolección y archivo de evidencia

Estado de esta nota

Este documento especifica las mejores prácticas actuales de Internet para el Comunidad de Internet, y solicita discusión y sugerencias para mejoras. La distribución de este memo es ilimitada.

Aviso de copyright

Copyright (C) The Internet Society (2002). Todos los derechos reservados.

Abstracto

Un "incidente de seguridad" como se define en el "Glosario de seguridad de Internet",

RFC 2828, es un evento de sistema relevante para la seguridad en el que el sistema

la política de seguridad es desobedecida o violada. El propósito de este documento es para proporcionar a los administradores del sistema con directrices sobre

la recopilación y el archivo de pruebas relevantes para dicha seguridad incidente.

Si la recopilación de pruebas se realiza correctamente, es mucho más útil en aprehender al atacante, y tiene muchas más posibilidades de ser admisible en caso de un procesamiento.

Tabla de contenido

1. Introducci3n.....	2
1.1 Convenciones utilizadas en este documento	2
2 principios rectores durante la recopilaci3n de pruebas	3
2.1 Orden de volatilidad	4
2.2 Cosas a evitar	4
2.3 Consideraciones de privacidad	5
2.4 Consideraciones legales	5
3 El procedimiento de recaudaci3n	6
3.1 Transparencia	6
3.2 Pasos de recopilaci3n	6
4 El procedimiento de archivo	7
4.1 Cadena de Custodia	7
4.2 El Archivo	7
5 herramientas que necesitar3n	7

Brezinski & Killalea Mejor práctica actual [Página 1]

6 referencias	8
7 Agradecimientos	8
8 Consideraciones de seguridad	8
9 direcciones de los autores	9
10 declaraci3n completa de los derechos de autor	10

1. Introducci3n

Un "incidente de seguridad" tal como se define en [RFC2828] es relevante para la seguridad

evento del sistema en el que se desobedece la pol3tica de seguridad del sistema o

de otra manera violado. El prop3sito de este documento es proporcionar Administradores del sistema con directrices sobre la recopilaci3n y el archivo evidencia relevante para tal incidente de seguridad. No es nuestro intenci3n de insistir en que todos los administradores del sistema sigan r3gidamente

estas pautas cada vez que tienen un incidente de seguridad. M3s bien, queremos proporcionar orientaci3n sobre lo que deber3an hacer si eligen Recopilar y proteger informaci3n relacionada con una intrusi3n.

Tal colecci3n representa un esfuerzo considerable por parte de la Administrador de sistema. Se ha avanzado mucho en los 3ltimos a3os acelerar la reinstalaci3n del sistema operativo y facilitar la reversi3n de un sistema a un estado "conocido", lo que hace la 'opci3n f3cil' es a3n m3s atractiva. Mientras tanto, poco ha sido hecho para proporcionar formas sencillas de archivar la evidencia (la dificultad opci3n). Adem3s, aumentar las capacidades de disco y memoria y m3s uso generalizado de t3cticas de sigilo y de cubrir sus pistas por parte de los atacantes han agravado el problema.

Si la recopilaci3n de pruebas se realiza correctamente, es mucho m3s 3til en aprehender al atacante, y tiene muchas m3s posibilidades de ser admisible en caso de un procesamiento.

Debe usar estas pautas como base para formular su procedimientos de recopilaci3n de evidencia del sitio, y debe incorporar su los procedimientos del sitio en su documentaci3n de manejo de incidentes. los las pautas en este documento pueden no ser apropiadas bajo todos jurisdicciones. Una vez que haya formulado la evidencia de su sitio procedimientos de recaudaci3n, debe tener la aplicaci3n de la ley para su la jurisdicci3n confirma que son adecuados.

1.1 Convenciones utilizadas en este documento

Las palabras clave "REQUERIDO", "DEBE", "NO DEBE", "DEBER3A", "NO DEBER3A", y "MAYO" en este documento deben interpretarse como se describe en "Clave palabras para su uso en RFCs para indicar los niveles de requisitos "[RFC2119].

2 principios rectores durante la recopilación de pruebas

- Adherirse a la política de seguridad de su sitio y comprometerse con personal apropiado de manejo de incidentes y aplicación de la ley.
- Capture una imagen lo más precisa posible del sistema.
- Mantenga notas detalladas. Estos deben incluir fechas y horas. Si posible generar una transcripción automática. (Por ejemplo, en Unix sistemas, se puede utilizar el programa 'script', sin embargo, la salida archivo que genera no debe ser a los medios que es parte de la evidencia). Las notas e impresiones deben estar firmadas y fechadas.
- Tenga en cuenta la diferencia entre el reloj del sistema y UTC. Para cada indicación de fecha y hora suministrada, indique si se utiliza la hora UTC o local.
- Prepárese para testificar (quizás años más tarde) describiendo todas acciones que tomaste y en qué momentos. Las notas detalladas serán vital.
- Minimice los cambios en los datos a medida que los va recopilando. Esto es no limitado a cambios de contenido; debes evitar actualizar el archivo o tiempos de acceso a directorios.
- Eliminar avenidas externas para el cambio.
- Cuando se enfrenta con una elección entre recolección y análisis primero debe hacer la recolección y luego analizarla.
- Aunque apenas necesita indicarlo, tus procedimientos deberán ser implementable. Como con cualquier aspecto de una respuesta de incidente política, los procedimientos deben ser probados para asegurar la viabilidad, particularmente en una crisis. Si es posible, los procedimientos deberán ser automatizado por razones de velocidad y precisión. Sea metódico.
- Para cada dispositivo, se debe adoptar un enfoque metódico que sigue las pautas establecidas en su procedimiento de recopilación. La velocidad a menudo será crítica así que cuando hay una cantidad de dispositivos que requieren un examen pueden ser apropiados para difundir el trabajo entre tu equipo para recolectar la evidencia en paralelo. Sin embargo, en un solo sistema dado, la colección debe hacerse paso por paso.
- Proceda de lo volátil a lo menos volátil (ver la Orden de volatilidad a continuación).

- Debería hacer una copia a nivel de bit de los medios del sistema. Si tu desea hacer análisis forenses debe hacer una copia a nivel de bit de su copia de evidencia para ese propósito, ya que su análisis casi con certeza altera los tiempos de acceso a los archivos. Evitar hacer forense en la copia de la evidencia.

2.1 Orden de volatilidad

Al recopilar evidencia, debe pasar de lo volátil a lo menos volátil. Aquí hay un ejemplo de orden de volatilidad para un típico sistema.

- registros, caché
- tabla de enrutamiento, caché de arp, tabla de proceso, estadísticas de núcleo memoria
- sistemas de archivos temporales
- disco
 - datos de registro y monitoreo remoto que son relevantes para el sistema en cuestión
 - configuración física, topología de red
 - medios de archivo

2.2 Cosas a evitar

Es demasiado fácil destruir la evidencia, aunque involuntariamente.

- No se apague hasta que haya completado la recopilación de pruebas. Mucha evidencia puede perderse y el atacante puede haber alterado el scripts / servicios de inicio / apagado para destruir la evidencia.
- No confíes en los programas en el sistema. Ejecuta tu evidencia reuniendo programas de medios apropiadamente protegidos (ver abajo).
- No ejecute programas que modifiquen el tiempo de acceso de todos los archivos el sistema (por ejemplo, 'tar' o 'xcopy').

- Al eliminar las avenidas externas para el cambio, tenga en cuenta que simplemente desconectar o filtrar de la red puede desencadenar "interruptores de hombre muerto" que detectan cuando están fuera de la red y borrar la evidencia.

2.3 Consideraciones de privacidad

- Respete las reglas y pautas de privacidad de su empresa y su jurisdicción legal. En particular, asegúrese de que no información recopilada junto con la evidencia que está buscando para estar disponible para cualquier persona que normalmente no tendría acceso a esta información. Esto incluye el acceso a los archivos de registro (que puede revelar patrones de comportamiento del usuario) así como también datos personales archivos.
- No inmiscuirse en la privacidad de las personas sin un fuerte justificación. En particular, no recopile información de áreas a las que normalmente no tiene motivos para acceder (como almacenes de archivos personales) a menos que tenga suficiente indicación que hay un incidente real.
- Asegúrese de tener el respaldo de la empresa establecida procedimientos para seguir los pasos que toma para recopilar evidencia de un incidente.

2.4 Consideraciones legales

La evidencia de la computadora necesita ser

- Admisible: debe cumplir con ciertas reglas legales antes de puede ser presentado ante un tribunal.
- Auténtico: debe ser posible vincular positivamente evidencia material al incidente.
- Completo: debe contar toda la historia y no solo una perspectiva particular.
- Confiable: no debe haber nada sobre cómo fue la evidencia recogido y posteriormente manejado que arroja dudas sobre su autenticidad y veracidad.
- Creíble: debe ser fácilmente creíble y comprensible por un tribunal.

3 El procedimiento de recogida

Sus procedimientos de recolección deben ser lo más detallados posible. Como es el caso con sus procedimientos generales de manejo de incidentes, deberán ser inequívoco, y debe minimizar la cantidad de toma de decisiones necesario durante el proceso de recolección.

3.1 Transparencia

Los métodos utilizados para recolectar evidencia deben ser transparentes y reproducibles. Usted debe estar preparado para reproducir precisamente el método que usó, y tiene esos métodos probados por independientes expertos.

3.2 Pasos de la colección

- ¿Dónde está la evidencia? Indique qué sistemas estaban involucrados en el incidente y de la cual se recopilaron pruebas.
- Establecer lo que puede ser relevante y admisible. Cuando en duda, errar por el lado de recoger demasiado en lugar de no suficiente.
- Para cada sistema, obtenga el orden de volatilidad correspondiente.
- Eliminar avenidas externas para el cambio.
- Siguiendo el orden de volatilidad, recopile la evidencia con herramientas como se discutió en la Sección 5.
- Registre la extensión de la deriva del reloj del sistema.
- Pregunte qué más puede ser evidencia mientras trabaja a través de los pasos de colección.
- Documenta cada paso.
- No te olvides de las personas involucradas. Toma notas de quién estuvo allí y qué estaban haciendo, qué observaban y cómo reaccionado

Siempre que sea posible, deberá considerar generar sumas de comprobación y firmando criptográficamente la evidencia recolectada, ya que esto puede hacerlo más fácil de preservar una fuerte cadena de evidencia. Al hacerlo, debes no alterar la evidencia.

4 El procedimiento de archivo

La evidencia debe ser estrictamente asegurada. Además, la Cadena de Custodia debe estar claramente documentado.

4.1 Cadena de custodia

Debería poder describir claramente cómo se encontró la evidencia, cómo se maneja y todo lo que le sucedió.

Los siguientes deben ser documentados

- Dónde, cuándo y por quién se descubrió la evidencia y recogido.
- Dónde, cuándo y quién maneja o examina la evidencia.
- Quién tuvo la custodia de la evidencia, durante qué período. Como fue almacenado
- Cuando la evidencia cambia la custodia, cuándo y cómo la transferencia ocurre (incluya números de envío, etc.).

4.2 Dónde y cómo archivar

Si es posible, use medios comunes (en lugar de algún almacenamiento oscuro) medios) se debe utilizar para archivar.

El acceso a la evidencia debe ser extremadamente restringido, y debe ser claramente documentado. Debería ser posible detectar desautorizado acceso.

5 herramientas que necesitarás

Debe tener los programas que necesita para hacer la recolección de evidencia y análisis forense en medios de solo lectura (p. ej., un CD). Deberías haber preparado

un conjunto de herramientas para cada uno de los sistemas operativos que administra antes de tener que usarlo.

Su conjunto de herramientas debe incluir lo siguiente:

- un programa para examinar procesos (por ejemplo, 'ps').
- programas para examinar el estado del sistema (por ejemplo, 'showrev', 'ifconfig', 'netstat', 'arp').
- un programa para hacer copias de bit a bit (por ejemplo, 'dd', 'SafeBack').

- programas para generar sumas de comprobación y firmas (por ejemplo, 'shasum', una 'suma de comprobación' habilitada 'dd', 'SafeBack', 'pgp').
- programas para generar imágenes centrales y para examinarlas (por ejemplo, 'gcore', 'gdb').
- scripts para automatizar la recopilación de pruebas (por ejemplo, The Coroner's Toolkit [FAR1999]).

Los programas en su conjunto de herramientas deben estar vinculados estéticamente, y no debería requerir el uso de ninguna biblioteca que no sean las de la medios de solo lectura. Incluso entonces, dado que se pueden instalar rootkits modernos a través de módulos de núcleo cargables, debe considerar que sus herramientas podría no proporcionarle una imagen completa del sistema.

Debe estar preparado para dar testimonio de la autenticidad y fiabilidad de las herramientas que usas

6 referencias

- [FAR1999] Farmer, D. y W Venema, "Computer Forensics Analysis Class Handouts ", <http://www.fish.com/forensics/>
- [RFC2119] Bradner, S., "Palabras clave para su uso en RFCs para indicar Niveles de requisitos ", BCP 14, RFC 2119, marzo de 1997.
- [RFC2196] Fraser, B., "Manual de seguridad del sitio", FYI 8, RFC 2196, Septiembre de 1997.
- [RFC2350] Brownlee, N. y E. Guttman, "Expectativas para la computadora" Respuesta a incidentes de seguridad ", FYI 8, RFC 2350, junio de 1998.
- [RFC2828] Shirey, R., "Internet Security Glossary", FYI 36, RFC 2828, mayo de 2000.

7 Agradecimientos

Agradecemos los constructivos comentarios recibidos de Harald Alvestrand, Byron Collie, Barbara Y. Fraser, Gordon Lennox, Andrew Rees, Steve Romig y Floyd Short.

8 Consideraciones de seguridad

Este documento completo analiza los problemas de seguridad.

9 direcciones de los autores

Dominique Brezinski
In-Q-Tel
1000 Wilson Blvd., Ste. 2900
Arlington, VA 22209
Estados Unidos

Correo electrónico: dbrezinski@In-Q-Tel.org

Tom Killalea
Lisi / n na Bro / n
Be / al A / tha na Muice
Co. Mhaigh Eo
IRLANDA

Teléfono: +1 206 266-2196
Correo electrónico: tomk@neart.org

10. Declaración completa de los derechos de autor

Copyright (C) The Internet Society (2002). Todos los derechos reservados.

Este documento y sus traducciones se pueden copiar y enviar a otros, y trabajos derivados que comentan o explican de otra manera o ayudar en su implementación puede ser preparado, copiado, publicado y distribuido, en todo o en parte, sin restricción de ningún amable, siempre que el aviso de copyright anterior y este párrafo sean incluido en todas esas copias y trabajos derivados. Sin embargo, esto el documento en sí no puede ser modificado de ninguna manera, como por el aviso de copyright o referencias a Internet Society u otra Organizaciones de Internet, excepto cuando sea necesario con el propósito de desarrollando estándares de Internet, en cuyo caso los procedimientos para los derechos de autor definidos en el proceso de Estándares de Internet deben ser seguido, o según sea necesario para traducirlo a otros idiomas que no sean Inglés.

Los permisos limitados concedidos anteriormente son perpetuos y no serán revocado por Internet Society o sus sucesores o cesionarios.

Este documento y la información contenida en este documento se proporcionan en un

"TAL CUAL" y LA SOCIEDAD DE INTERNET Y LA INGENIERÍA DE INTERNET TASK FORCE RECHAZA TODAS LAS GARANTÍAS, EXPRESAS O IMPLÍCITAS, INCLUYENDO PERO NO LIMITADO A CUALQUIER GARANTÍA QUE EL USO DE LA INFORMACIÓN AQUÍ NO INFRINGE CUALQUIER DERECHO O CUALQUIER GARANTÍA IMPLÍCITA DE COMERCIALIZACIÓN O IDONEIDAD PARA UN PROPÓSITO PARTICULAR.

Reconocimiento

La financiación para la función del Editor de RFC es proporcionada actualmente por el Sociedad de Internet.